

Lucas Zacarias Martins Neves

**Deteccção de vulnerabilidades de memória em C:
Abordagem integrando VSA e HOFG**

São Paulo

2026

Lucas Zacarias Martins Neves

Detecção de vulnerabilidades de memória em C: Abordagem integrando VSA e HOFG

Proposta de Trabalho de Conclusão de Curso
apresentado ao SENAC Santo Amaro como
requisito parcial para aprovação na disciplina
de TCC1 do curso de Ciência da computação.

SENAC – Serviço Nacional de Aprendizagem Comercial
Unidade Santo Amaro
Bacharelado em Ciência da computação

Orientador: Prof. Leonardo Massayuki Takuno

São Paulo
2026

Resumo

Vulnerabilidades de segurança de memória em linguagens como C e C++ representam uma parcela significativa das falhas críticas de software na indústria. Ferramentas de análise estática são fundamentais para a detecção precoce dessas falhas, mas frequentemente esbarram em limitações, como a alta taxa de falsos positivos. O modelo estrutural *Heap Object Flow Graph* (HOFG) destaca-se por rastrear o fluxo de blocos alocados dinamicamente na memória *Heap*; contudo, sua implementação original apresenta dificuldades no tratamento de aritmética de ponteiros, resultando em cerca de 14% de imprecisões em testes preliminares. Para mitigar essa limitação, este trabalho propõe o desenvolvimento de um analisador estático que integra o HOFG com a técnica de interpretação abstrata *Value-Set Analysis* (VSA). A ferramenta, construída na linguagem Zig e operando sobre a Representação Intermediária do compilador LLVM (LLVM IR), adota um processamento modular de arquivos para otimizar o consumo de memória RAM. Nessa arquitetura, o VSA atua como um validador numérico sobre o grafo, estimando os limites de deslocamento (*offsets* e *ranges*) que cada endereço abstrato pode assumir e impedindo a formação de arestas de fluxo inválidas. A avaliação da precisão e eficiência da solução proposta será conduzida utilizando casos sintéticos do *Juliet Test Suite* e análises de projetos reais de código aberto. O objetivo central é demonstrar que a unificação entre o rastreamento direcional do HOFG e a abstração numérica do VSA permite reduzir consideravelmente os falsos positivos na detecção de vulnerabilidades de memória (tais como CWE-401, CWE-415 e CWE-416), garantindo maior segurança e escalabilidade no ciclo de desenvolvimento de software.

Palavras-chave: Análise estática, Vulnerabilidades de memória, HOFG.

Lista de ilustrações

Figura 1 – Função em C utilizada como base para as representações intermediárias.	13
Figura 2 – Código presente na figura 1 na forma AST de baixa fidelidade	14
Figura 3 – Código presente na figura 1 em sua forma CFG	15
Figura 4 – Código presente na figura 1 adaptado para a forma SSA de forma didática	17
Figura 5 – Cronograma de atividades – Diagrama de Gantt	35

Lista de Abreviaturas e Siglas

A lista a seguir reúne, em ordem alfabética, as abreviaturas e siglas utilizadas neste trabalho, acompanhadas de seus respectivos significados.

Abreviatura	Significado
AST	<i>Abstract Syntax Tree</i> (Árvore sintática abstrata)
CFG	<i>Control Flow Graph</i> (Grafo de fluxo de controle)
CVE	<i>Common Vulnerabilities and Exposures</i>
CVSS	<i>Common Vulnerability Scoring System</i>
CWE	<i>Common Weakness Enumeration</i>
HOFG	<i>Heap Object Flow Graph</i>
IR	<i>Intermediate Representation</i> (Representação intermediária)
LoC	<i>Lines of Code</i> (Linhas de código)
MAD	<i>Memory allocation/deallocation</i> (Alocação e desalocação de memória)
MSRC	<i>Microsoft Security Response Center</i>
NVD	<i>National Vulnerability Database</i>
SSA	<i>Static Single Assignment</i> (Atribuição única estática)
VSA	<i>Value-Set Analysis</i>

Sumário

1	INTRODUÇÃO	7
1.1	Contexto	7
1.2	Justificativa	8
1.3	Hipótese	8
1.4	Objetivos	9
1.4.1	Objetivo geral	9
1.4.2	Objetivos específicos	9
2	REVISÃO BIBLIOGRÁFICA	11
2.1	Metodologia da pesquisa bibliográfica	11
2.2	Referencial	12
2.2.1	Memória <i>Heap</i>	12
2.2.2	Análise estática	12
2.2.2.1	Árvore sintática abstrata (AST)	13
2.2.2.2	Grafo de fluxo de controle (CFG)	14
2.2.2.3	Níveis de sensibilidade da análise estática	16
2.2.2.4	Forma de atribuição única estática (SSA)	16
2.2.2.5	Limitações da análise estática em códigos-fonte	17
2.2.2.6	Relevância da análise estática em códigos-fonte	18
2.2.3	LLVM	19
2.2.3.1	Implementação do Design de três fases	19
2.2.3.2	Representação Intermediária (LLVM IR)	20
2.2.4	Vulnerabilidades de memória	20
2.2.4.1	<i>Common Weakness Enumeration</i> (CWE)	21
2.2.4.2	CWE-401	21
2.2.4.3	CWE-415	22
2.2.4.4	CWE-416	22
2.2.4.5	<i>Common Vulnerabilities and Exposures</i> (CVE)	22
2.2.5	<i>Heap Object Flow Graph</i> (HOFG)	23
2.2.5.1	Geração do HOFG para o programa inteiro	23
2.2.6	<i>Value-Set Analysis</i>	26
2.2.6.1	Regiões de memória (<i>Memory-Regions</i>)	26
2.2.6.2	<i>Abstract Locations</i> (A-Locs)	27
2.2.6.3	<i>Value-Set</i>	27
2.3	Métricas de Avaliação	28

2.3.1	Juliet Test Suite	28
2.3.2	Casos aplicados	29
2.4	Trabalhos relacionados	29
2.4.1	Trabalho 1: <i>Memory leak detection using Heap Object Flow Graph (HOFG)</i> .	30
2.4.2	Trabalho 2: <i>LeakGuard: Detecting Memory Leaks Accurately and Scalably</i> .	31
2.4.3	Trabalho 3: <i>Infer - An Automatic Program Verifier for Memory Safety of C Programs</i>	32
3	DESENVOLVIMENTO	34
3.1	Solução proposta	34
3.2	Cronograma de trabalho	35
	REFERÊNCIAS	36

1 Introdução

Este capítulo introdutório está estruturado nas subseções [1.1 Contexto](#), [1.2 Justificativa](#), [1.3 Hipótese](#) e [1.4 Objetivos](#), abrangendo objetivo geral e objetivos específicos.

1.1 Contexto

Em um levantamento realizado pela *Microsoft Security Response Center* (MSRC) realizado em 2019 ([THOMAS, 2019](#)), foi apurado que aproximadamente 70% das vulnerabilidades corrigidas em softwares da multinacional entre o período de 2004 e 2018 tem ligação a falhas de segurança de memória nas linguagens C e C++, causadas por desenvolvedores que inseriram tais erros em seus códigos sem perceber. Além disso, a situação teve piora não somente com o incremento da base de código da empresa, mas também com a adição de mais código aberto aos seus projetos.

É pontuado ainda pela Microsoft que existem métodos para auxiliar os desenvolvedores a desenvolver código seguro, tais métodos variam desde ferramentas e algoritmos desenvolvidos para análise do próprio código escrito até a guias e metodologias de desenvolvimento para software seguro, treinamentos internos, reuniões para monitoria e análise de código. Salvaguardas que atuam em todas as camadas do desenvolvimento de software, e mesmo com tais itens, tais vulnerabilidades de memória continuam predominantes.

Dando destaque às ferramentas de análise de código estático, por vezes exigem tempo para que os desenvolvedores aprendam a fazer uso do analisador, cenário este que torna o uso de tais ferramentas algo inviável quando o tempo não é aliado. Além disso, tais ferramentas não garantem que todas as vulnerabilidades e possíveis falhas de um código sejam encontradas, pois focam numa análise do código-fonte do software, sendo escrito numa linguagem de alto nível e não na linguagem de máquina gerada pelo compilador que será executada pelo hardware ([BALAKRISHNAN; REPS, 2010](#)).

Além de métodos de código estático, outra opção também pontuada pela MSRC para a diminuição de ocorrências, seria o uso de linguagens de programação *memory-safe*, ou seja, que retiram das mãos de desenvolvedores os ônus de preocupações com segurança de memória e a adicionam na própria linguagem, fazendo gerenciamento de memória ou empregando regras estritas na fase de compilação, evitando tais vulnerabilidades. Um exemplo de linguagem de programação *memory-safe* é o Rust, sendo desenvolvido pela Mozilla e que tem como um de seus princípios a segurança de memória.

1.2 Justificativa

Apesar da existência de linguagens de programação que integram mecanismos designados para o gerenciamento da memória *Heap*, tais como o C# e Java, e até mesmo com a existência de linguagens de programação que tem como objetivo principal a segurança e estabilidade do programa, como ocorre com o Rust (THOMAS, 2019), a reescrita de projetos inteiros frequentemente apresenta custos excessivos de portabilidade. Diante disso, a manutenção e o desenvolvimento na linguagem original se tornam necessários, cenário este que pode ocorrer em projetos construídos em linguagens de programação inseguras, como C e C++.

Para garantir maior segurança de tais projetos, um analisador de código pode ser desenvolvido como solução, com foco na detecção de potenciais vazamentos e problemas derivados da má gestão de dados alocados dinamicamente. Embora a análise estática de códigos-fonte apresente limitações — dentre elas, as limitações apresentadas por Balakrishnan (2007) —, tais abordagens continuam sendo úteis no ciclo de desenvolvimento de software, havendo como uma de suas principais justificativas para adoção a possibilidade de identificar e mitigar vulnerabilidades ainda nas fases iniciais do projeto (MØLLER; SCHWARTZBACH, 2018).

Além disso, embora possam ocorrer mudanças no código-fonte originadas em tempo de compilação para arquiteturas específicas, havendo ainda a possibilidade de falhas geradas pelo próprio compilador, a grande maioria das vulnerabilidades relacionadas à segurança de memória são geradas pelos próprios desenvolvedores de forma desavisada (THOMAS, 2019), permanecendo no código-fonte e passíveis de detecção através de algoritmos.

1.3 Hipótese

A hipótese do projeto está numa integração entre dois métodos de análise estática.

O primeiro método é o *Heap Object Flow Graph* (HOFG) (C; CHERAMANGALATH, 2023), sendo uma representação do fluxo dos blocos de memória alocados na *Heap*, na qual os vértices do grafo são obtidos a partir das variáveis do programa que são ponteiros para a memória *Heap*.

Para automatizar a detecção de vulnerabilidades de memória, foi desenvolvido o *HOFG-Analyser*, uma ferramenta de análise estática que utiliza a representação HOFG para a detecção de tais vulnerabilidades. O processo tem início com a compilação do código-fonte por meio da infraestrutura do *framework* LLVM, com objetivo de gerar a representação intermediária (LLVM IR) da aplicação. A partir dessa versão estruturada na IR, o grafo de fluxo de objetos na memória *Heap* é construído, abrangendo o programa completo. Após a geração completa do grafo, o *HOFG-Analyser* realiza as verificações necessárias a procura de potenciais vazamentos ou falhas de memória (C; CHERAMANGALATH, 2023).

Porém, o *HOFG-Analyser* obteve 14% de falsos positivos em seus testes, apresentando dificuldades com aritmética de ponteiros presente na linguagem C, ocorrendo pois, dado um ponteiro p , as operações $q = p + 1$ e $q = p$ resultam na adição de uma mesma aresta do ponteiro p para o ponteiro q no grafo. Como consequência, as instruções $free(p)$ e $free(q)$ seriam interpretadas de forma simplificada como a liberação do mesmo objeto na memória *Heap* (C; CHERAMANGALATH, 2023).

Para lidar com as dificuldades presentes pela aritmética de ponteiros e ser possível diminuir a taxa de falsos positivos do HOFG original, uma integração com o *Value-Set Analysis* (VSA) (BALAKRISHNAN, 2007) poderia ser realizada. O VSA, técnica de interpretação abstrata originalmente aplicada para análise de executáveis, tem o objetivo de encontrar uma aproximação segura para o conjunto de valores que cada objeto de dados pode armazenar em cada ponto de um programa.

Ao integrar o VSA ao HOFG, o mapeamento dos limites de intervalos de endereços abstratos na memória *Heap* se torna possível, reduzindo a taxa de falsos positivos na detecção de vulnerabilidades comparado a análise baseada unicamente ao modelo HOFG padrão.

1.4 Objetivos

Os objetivos deste trabalho dividem-se em um objetivo principal e objetivos secundários, os quais representam passos necessários para que o propósito central seja alcançado.

1.4.1 Objetivo geral

O objetivo principal do trabalho é demonstrar a viabilidade da integração da representação *Heap Object Flow Graph* (HOFG) com técnicas de *Value-Set Analysis* (VSA) para o rastreamento preciso de ponteiros (*offset* e *range*), com foco na detecção de vulnerabilidades de memória em análise estática de código para a linguagem C.

1.4.2 Objetivos específicos

1. Fundamentar teoricamente a integração do *Value-Set analysis* à estrutura do *Heap Object Flow Graph* (HOFG), demonstrando como essa abordagem conjunta pode mitigar as limitações de rastreamento de ponteiros e reduzir a taxa de falsos positivos da análise estática.
2. Implementar motor de análise estática processando a representação intermediária LLVM IR, construindo os algoritmos necessários para a extração e geração do HOFG e sua integração com o VSA.

3. Avaliar a precisão e a eficiência do analisador implementado utilizando conjuntos de testes que exploram falhas da linguagem C (como vazamentos de memória e usos após desalocação).
4. Comparar os resultados obtidos com referências comparativas tendo como foco principal a taxa de falsos positivos e verdadeiro positivos, e comparar o tempo e custo computacional da implementação original do HOFG, para validar o impacto da integração.

2 Revisão Bibliográfica

A revisão bibliográfica deste artigo está estruturada nas subseções 2.1 Metodologia da pesquisa bibliográfica, abrangendo a forma como a pesquisa bibliográfica foi conduzida; 2.2 Referencial, contendo os principais conceitos, teorias e definições que constituem a base fundamental deste trabalho; 2.3 Métricas de avaliação, detalhando como a solução proposta será avaliada e o que será levado em consideração; e, por fim, 2.4 Trabalhos relacionados, subseção que contém breve análise de três artigos com objetivos similares, destacando suas características, resultados obtidos e, principalmente, as distinções em relação a este trabalho.

2.1 Metodologia da pesquisa bibliográfica

A pesquisa bibliográfica foi realizada primariamente no motor de busca Google Acadêmico (*Google Scholar*), utilizando as seguintes strings de busca:

- *"memory leak"AND "static analysis"*
- *"memory leak"AND "dynamic analysis"*
- *("memory safety"OR "memory leak"OR "memory corruption") AND ("empirical study"OR "quantitative analysis") AND "vulnerability"*

A exclusão de artigos foi guiada por critérios de inclusão e exclusão predefinidos. Foram considerados trabalhos publicados no período entre 2022 e 2026, primariamente em língua inglesa e que abordassem diretamente métodos de identificação de vulnerabilidades de memória.

Após a busca inicial, técnica de triagem (*screening*) foi empregada, consistindo na avaliação do título e do resumo de cada artigo obtido. Essa etapa resultou na seleção de 11 artigos, focados em métodos de análise para detecção dessas vulnerabilidades. Dentre estes, o trabalho seminal referente ao modelo *Heap Object Flow Graph* (HOFG) ganhou destaque por ter como foco a adaptação da estrutura para a detecção de vulnerabilidades de memória na linguagem C.

Em seguida, foram mapeados os trabalhos seminais referenciadas pelos autores. Essa etapa de pesquisa em cadeia (*snowballing*), totalizando 24 artigos. Contudo, com o modelo HOFG estabelecido como base estrutural, a etapa de leitura recebeu um filtro de exclusão mais restrito, sendo considerados e lidos artigos com ligação direta a base estrutural.

Por fim, a partir de necessidades conceituais levantadas durante a leitura de tais artigos, busca complementar foi conduzida, utilizando como referência a literatura clássica, livros técnicos e documentações oficiais com o objetivo de obter definições estruturais necessárias.

2.2 Referencial

Para fundamentar o desenvolvimento do analisador proposto, esta seção estabelece os alicerces teóricos da pesquisa. O texto está estruturado a partir dos conceitos de Memória *Heap* (2.2.1) e Análise Estática (2.2.2), avançando para a infraestrutura de compilação LLVM (2.2.3), e a classificação de Vulnerabilidades de Memória (2.2.4). Por fim, são detalhados os dois modelos centrais que embasam a solução: *Heap Object Flow Graph* (2.2.5) e *Value-Set Analysis* (2.2.6).

2.2.1 Memória *Heap*

A memória *Heap* é uma área da memória virtual de um processo utilizada para a alocação dinâmica de memória. Tal região tem início logo após a área de dados não inicializados do programa e cresce para cima, em direção a endereços de memória mais altos. Para cada processo, o *kernel* mantém uma variável *brk* (sendo pronunciada *break*, ou quebra) que aponta para o topo da *Heap* (BRYANT; O'HALLARON, 2010). Um alocador dinâmico gerencia a *Heap* como uma coleção de blocos de tamanhos variados. Cada bloco é um segmento (*chunk*) contínuo de memória virtual que pode estar em dois estados: alocado ou livre. Um bloco alocado é reservado para uso de forma explícita pela aplicação, permanecendo neste estado até que seja liberado, tanto de forma explícita, pelo aplicativo, quanto de forma implícita, pelo próprio alocador de memória (como em sistemas com *Garbage Collection*). E, por sua vez, um bloco livre está disponível para ser alocado, e permanece assim até que, de forma explícita, seja alocado através de uma nova requisição de alocação feita pela aplicação. O fato de que, por vezes, o tamanho exato de certas estruturas de dados que serão utilizados em um programa só se tornam conhecidos até que o mesmo seja executado se torna o principal motivo para a utilização da alocação dinâmica de memória e, conseqüentemente, da memória *Heap* (BRYANT; O'HALLARON, 2010).

2.2.2 Análise estática

A análise estática de programas é definida como a arte de raciocinar sobre o comportamento de programas sem de fato executá-los. O seu objetivo principal é responder de forma automatizada perguntas sobre os possíveis comportamentos de um código. Isto é útil não apenas em otimizações realizadas por um compilador para produzir código binário eficiente, mas também para detecção automatizada de erros e outras ferramentas que podem ajudar programadores. Um analisador estático de programas é um programa que faz inferências sobre o comportamento de outros programas (MØLLER; SCHWARTZBACH, 2018).

O código-fonte escrito em C apresentado na figura 1 servirá como exemplo para ilustrar as transformações abordadas nesta seção. Serão obtidas as suas representações

Figura 1 – Função em C utilizada como base para as representações intermediárias.

```
1 int exemplo() {  
2  
3     int i = 0;  
4     int v = 10;  
5  
6     do {  
7         if (i % 2 == 0) {  
8             i = i + 1;  
9         }  
10        else {  
11            i = i * 2;  
12        }  
13    } while (i < v);  
14  
15    return i;  
16 }
```

Fonte: Elaborado pelo autor (2026)

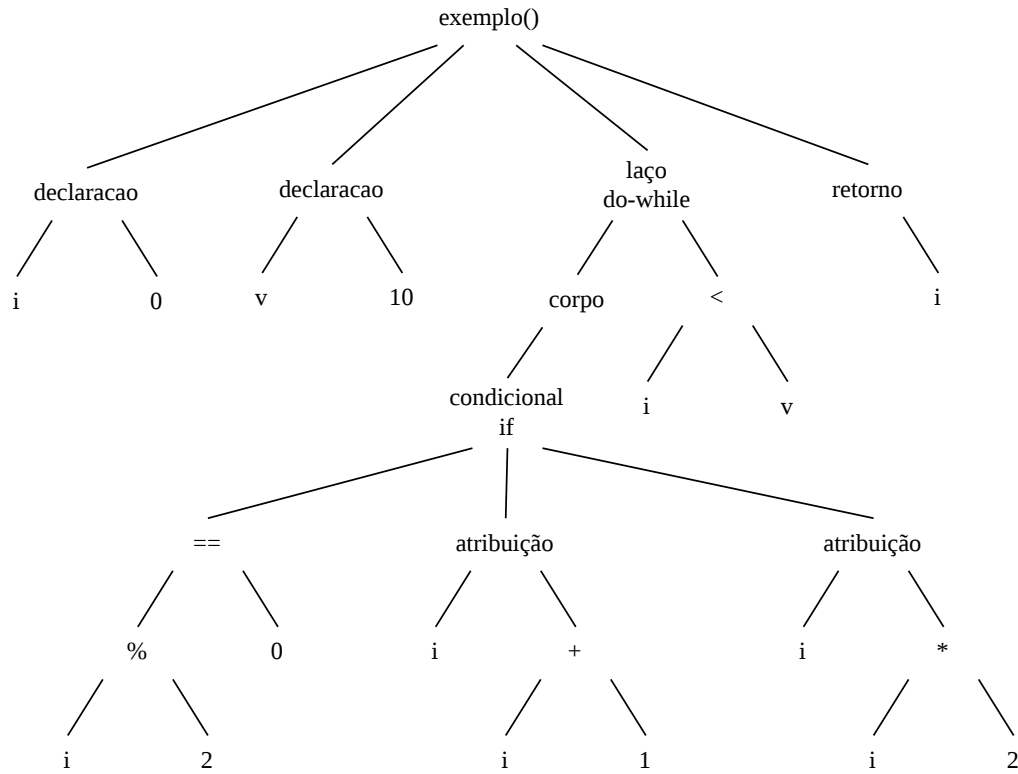
intermediárias: a Árvore sintática abstrata (AST), o Grafo de fluxo de controle (CFG) e, por fim, a forma de Atribuição Única Estática (SSA).

2.2.2.1 Árvore sintática abstrata (AST)

Segundo [Aho et al. \(2009\)](#), as árvores sintáticas abstratas (ASTs), ou simplesmente árvores sintáticas, nas quais cada nó interno representa um operador da expressão, e seus nós filhos representam os respectivos operandos. Além disso, as ASTs se assemelham às árvores de derivação até certo nível, diferenciando-se pelo fato de que os nós interiores da AST representam construções de programação, ao passo que na árvore de derivação os nós interiores representam símbolos não-terminais. Outra diferença é a ausência de símbolos não-terminais auxiliares, tais como aqueles que representam termos, fatores, ou outras variações de expressões, na AST. Essa falta ocorre pois tais detalhes sintáticos são desnecessários para a fase de tradução, resultando em uma representação mais condensada e focada na semântica do código-fonte.

A figura 3 ilustra a representação AST da função exemplo exibida na figura 1. Por ser uma representação de baixa fidelidade, a árvore foca na estrutura lógica das operações, abstraindo a pontuação original do código-fonte. A raiz ramifica-se sequencialmente para as operações principais: as declarações das variáveis *i* e *v*, a estrutura de repetição **do-while**, declarando seu corpo e a sua condição de parada *<*, e, por fim, o nó de retorno da função.

Figura 2 – Código presente na figura 1 na forma AST de baixa fidelidade



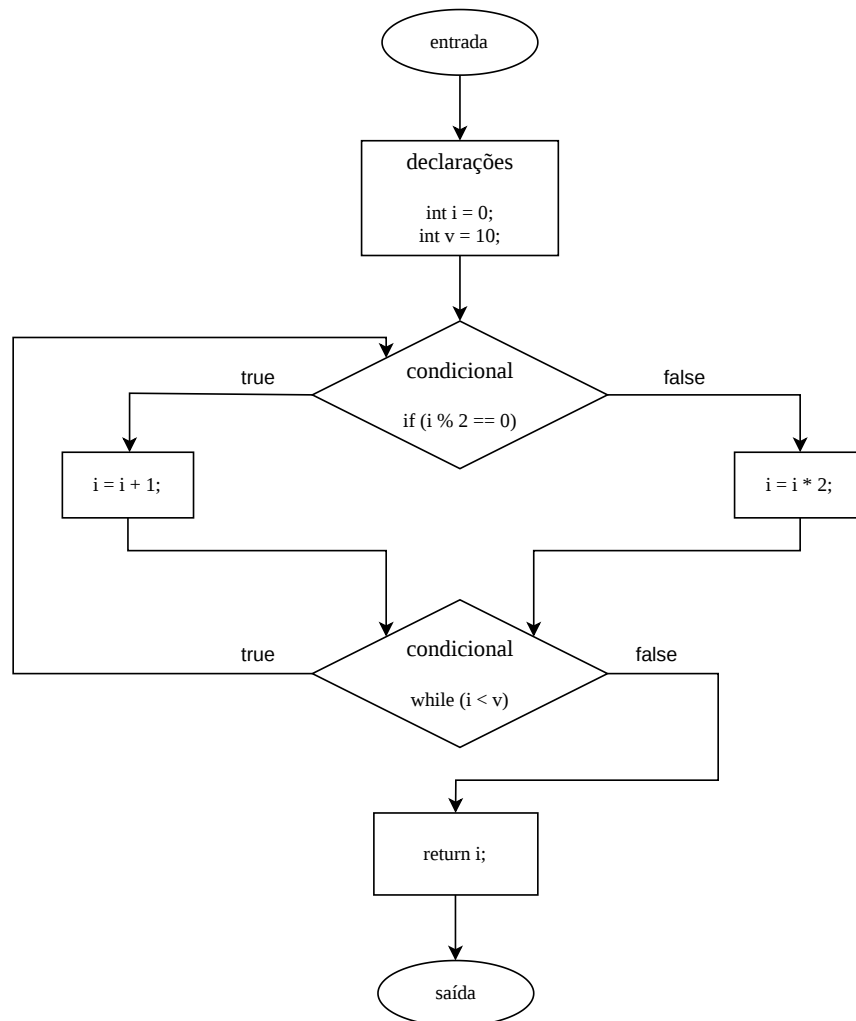
Fonte: Elaborado pelo autor (2026)

2.2.2.2 Grafo de fluxo de controle (CFG)

Um grafo de fluxo de controle (*Control Flow Graph*, ou CFG) é um grafo direcionado, no qual seus vértices correspondem a declarações (instruções) e arestas representam possíveis caminhos do fluxo de controle durante a execução. Para simplificar as representações e algoritmos que operam sobre o grafo, é assumido por convenção que todo CFG possui um único ponto de entrada (*entry*) e um único ponto de saída (*exit*), os quais podem ser compreendidos como comandos vazios (*no-ops*). Além disso, se v é um vértice presente em um CFG, então $pred(v)$ denota o conjunto de vértices predecessores e $succ(v)$ o conjunto de vértices sucessores. Para programas totalmente normalizados, cada vértice corresponde a apenas uma operação (MØLLER; SCHWARTZBACH, 2018).

O emprego de um CFG se dá pelo fornecimento de uma representação de código que mantém a ordem em que as instruções são executadas, criando contraste com ASTs, que representam a estrutura sintática do programa enquanto ignoram a ordem de execução dos comandos. Por fornecer tal ordem de execução de instruções, o CFG se torna adequado para análises sensíveis ao fluxo (*flow-sensitive analysis*), especialmente a análise de fluxo de dados (*dataflow analysis*) (MØLLER; SCHWARTZBACH, 2018).

Figura 3 – Código presente na figura 1 em sua forma CFG



Fonte: Elaborado pelo autor (2026)

Os CFGs podem ser construídos de maneira indutiva para as diferentes estruturas de uma linguagem. Comandos em sequência são unidos, eliminando a saída do primeiro e a entrada do segundo, bem como estruturas de decisão (*if-else*) e laços de repetição (*while*) dividem o fluxo em arestas de ramificação, comumente rotuladas com as condições verdadeiro ou falso (MØLLER; SCHWARTZBACH, 2018).

A figura 3 apresenta o CFG correspondente à execução da função **exemplo**, presente na figura 1. A partir do nó de entrada, o fluxo sequencial passa pelas declarações iniciais até atingir a condicional `if(i % 2 == 0)`. As arestas direcionadas ilustram as duas ramificações mutuamente exclusivas que convergem para a avaliação do laço `while (i < v)`. Uma aresta de retorno demonstra o ciclo do laço quando a condição é mantida como verdadeira, ao passo que o caminho alternativo conduz à instrução de retorno e ao término

da função.

2.2.2.3 Níveis de sensibilidade da análise estática

Os níveis de sensibilidade são características que definem como uma ferramenta de análise estática modela e percorre o código-fonte. No que diz respeito à ordem de execução, as análises podem ser categorizadas em duas abordagens principais (MØLLER; SCHWARTZBACH, 2018):

Análise sensível ao fluxo, (*Flow-Sensitive*): Abordagem que leva em consideração a ordem em que as instruções de um programa são executadas, a partir disso, se torna capaz de distinguir entre os diferentes pontos de um programa. Por exemplo, se uma variável a recebe uma atribuição na linha 2 e outra atribuição na linha 4, a análise sensível ao fluxo é capaz de reconhecer que uma leitura realizada na linha 3 dependerá estritamente do valor definido na linha 2, e não da linha 4 (MØLLER; SCHWARTZBACH, 2018).

Análise insensível ao fluxo, (*Flow-Insensitive*): Abordagem que ignora a ordem de execução das instruções de um programa. Tal análise enxerga o código como um conjunto não ordenado de comandos. Por conta disso, tais análises frequentemente utilizam ASTs como representação base, já que tal estrutura capta a sintaxe global do programa, sem haver preocupação com o sequenciamento temporal do fluxo. Seu uso está em métodos que não dependem da cronologia de um programa para realizar sua análise, tais como a análise de tipos (MØLLER; SCHWARTZBACH, 2018).

2.2.2.4 Forma de atribuição única estática (SSA)

O SSA (*Static Single Assignment*) é uma forma de representação de código intermediário, tem como ponto-chave as características de que cada definição de variável possui um nome distinto, e de que cada uso refere-se a apenas uma única definição, sendo essas também as duas restrições da representação, significando que, caso um programa atenda tais restrições, tal programa estará em sua forma SSA. Para garantir essa singularidade, variáveis que sofrem múltiplas atribuições no código-fonte são renomeadas, sendo criadas versões distintas para cada nova atribuição (por exemplo, v_1 , v_2 , v_3) (SINGER, 2022).

Além disso, em programas com desvios do fluxo de controle, contendo blocos condicionais e laços de repetição, diferentes versões da mesma variável podem chegar ao mesmo ponto de convergência no Grafo de Fluxo de Controle (CFG). São inseridas então, nesses pontos de junção, as chamadas funções ϕ (*phi functions*), possuindo N argumentos correspondentes aos N caminhos do fluxo de controle convergentes, e seleciona a versão correta da variável com base no caminho de execução tomado pelo programa. Sendo criada inicialmente para facilitar o desenvolvimento de transformações de programa de alto nível, a forma ganhou popularidade pelas suas propriedades que permitem a simplificação de algoritmos e a redução da complexidade computacional das análises de fluxo de dados. Atualmente, é amplamente utilizada por compiladores de código aberto e comerciais, como é o caso do

Figura 4 – Código presente na figura 1 adaptado para a forma SSA de forma didática

```
1  int exemplo() {  
2      i1 = 0;  
3      v1 = 10;  
4  
5      do {  
6          i2 = phi(i1, i5);  
7  
8          if (i2 % 2 == 0) {  
9              i3 = i2 + 1;  
10         }  
11         else {  
12             i4 = i2 * 2;  
13         }  
14  
15         i5 = phi(i3, i4);  
16  
17     } while (i5 < v1);  
18  
19     return i5;  
20 }
```

Fonte: Elaborado pelo autor (2026)

LLVM, sendo uma estrutura fundamental para a análise estática de programas (SINGER, 2022).

O trecho de código, presente na figura 4, ilustra uma adaptação didática da função exemplo presente na figura 1 para a forma SSA. Para satisfazer as propriedades da representação SSA, a variável original *i* é versionada em múltiplas instâncias independentes. Além disso, o código exibe o uso de funções ϕ em dois pontos de convergência do fluxo: no início do laço *do-while*, para mesclar o valor inicial da variável com o valor propagado pela iteração anterior (*i2* = *phi*(*i1*, *i5*)), e logo após a condicional *if-else*, para unificar as ramificações exclusivas da execução (*i5* = *phi*(*i3*, *i4*)) antes da verificação para continuidade do laço.

2.2.2.5 Limitações da análise estática em códigos-fonte

Os métodos de análise estática não garantem que todas as vulnerabilidades de um código-fonte sejam encontradas. Dentre os motivos, sendo listados por Balakrishnan (2007), estão:

- O uso de bibliotecas já compiladas (tais como as DLLs) em programas, por vezes sem estar disponíveis em sua forma fonte. Gerando a necessidade de realizar esboços que simulam os efeitos das chamadas de função de tais bibliotecas. Por não poder

realizar a análise em tais bibliotecas, é possível que a mesma possua erros, não sendo detectados durante a análise estática sendo realizada, resultando em inconsistências.

- O fato de que códigos-fonte são modificados pelo compilador durante a compilação, realizando otimizações e adicionando instrumentações de código, sendo itens não encontrados pelas ferramentas que analisam tais códigos.
- O código-fonte de um programa pode ser escrito em mais de uma linguagem de programação, tornando mais dificultoso o design de tais ferramentas de análise, pois precisam dar suporte a múltiplas linguagens de programação, cada uma contendo suas características e peculiaridades.
- E, mesmo em um código-fonte escrito em apenas uma linguagem de programação de alto nível, tal código pode conter código escrito em *assembly* em certos locais. Ferramentas de análise estática normalmente ignoram o código *assembly* adicionado, ou não levam a análise além do código *assembly* adicionado.

2.2.2.6 Relevância da análise estática em códigos-fonte

Mesmo com as limitações presentes nos métodos de análise estática de códigos-fonte — dentre elas, as citadas por Balakrishnan (2007) —, tais abordagens continuam sendo úteis no ciclo de desenvolvimento de software. Um dos principais motivos para sua adoção é o fato de que tais métodos permitem que vulnerabilidades sejam encontradas ainda nas fases iniciais do projeto, viabilizando a correção prévia e evitando custos elevados nas etapas finais ou em produção (MØLLER; SCHWARTZBACH, 2018).

Além disso, apesar do código-fonte ser modificado em tempo de compilação através das otimizações e instrumentações e existindo a possibilidade de erros gerados pelo compilador para arquiteturas específicas, a maioria das falhas reside no código original. Sendo apontado pela Microsoft, na qual 70% das falhas corrigidas vinculadas a um CVE em seus softwares tinham como origem vulnerabilidades de memória geradas pelos próprios desenvolvedores, estando presentes e detectáveis em seus respectivos códigos-fonte (THOMAS, 2019).

Por fim, quanto ao uso de bibliotecas pré-compiladas, bem como a mescla de múltiplas linguagens de programação e trechos escritos em linguagem *assembly*, os métodos de análise estática costumam adotar abordagens conservadoras (isto é, seguras). Ao serem encontrados, tais chamadas para funções e trechos inalcançáveis geram alertas durante a análise, lidando com o desconhecido como se pertencesse ao pior cenário possível. Embora essa característica gere falsos positivos durante a avaliação, é cumprido o propósito de evitar falsos negativos. Garantindo, dessa forma, que nenhum ponto cabível de vulnerabilidade passe despercebido e que erros reais sejam tratados (MØLLER; SCHWARTZBACH, 2018).

2.2.3 LLVM

Segundo [Lattner e Adve \(2004\)](#), o LLVM é uma infraestrutura de compilação designada para prover transparência e análise e transformação de programas de forma persistente durante todo o seu ciclo de vida. O sistema é fundamentado em uma representação intermediária (IR) de baixo nível, baseada na sua forma SSA, permitindo uma ponte universal entre diferentes linguagens e arquiteturas. A arquitetura introduz recursos fundamentais para a análise de código:

- Um simples sistema de tipagem independente de linguagem que expõe os tipos primitivos usados comumente para implementar atributos de linguagens de alto nível.
- Instrução para endereçamento aritmético, sendo diferente do C puro, o LLVM utiliza uma instrução específica para cálculos de ponteiros que preserva informações de tipo e limites de estruturas, sendo essencial para detectar acessos inválidos.
- Mecanismo uniforme de exceções, utilizado para implementar recursos de tratamento de exceções comumente encontrados em linguagens de alto nível de forma eficiente.

2.2.3.1 Implementação do Design de três fases

Num compilador moderno, três componentes principais são aplicados ([LATTNER, 2011](#)), sendo eles:

- O *front end*, responsável por analisar o código-fonte, checar erros e construir a AST específica para a linguagem em questão.
- O otimizador, responsável por realizar transformações de código numa tentativa de melhorar o tempo de execução do código, realizando, por exemplo, remoções de itens redundantes que seriam computados.
- O *back end*, também conhecido como o gerador de código. Responsável por mapear o código para o conjunto de instruções da arquitetura alvo. Dentre os itens comumente encontrados no back end, estão inclusos a seleção de instruções, alocação de registradores e o escalonamento de instruções.

Com tal padrão a portabilidade de um compilador para uma nova linguagem de programação fonte gera a necessidade de implementação do novo *front end*, mas permitindo que o otimizador e o *back end* sejam reutilizados. Porém, esse benefício não fora alcançado em todos os casos já que implementações do padrão de três fases, numa época em que o LLVM estava tendo seu início, em linguagens como Perl, Python, Ruby e Java não compartilhavam código entre si, ou seja, cada uma destas linguagens possuía sua própria implementação de *front end*, otimizador e *back end* ([LATTNER, 2011](#)).

2.2.3.2 Representação Intermediária (LLVM IR)

A representação intermediária é o aspecto principal do LLVM, sendo a forma que compilador utiliza para representar o código-fonte sendo compilado. É designada para análises de nível intermediário e transformações que são encontradas no setor de otimização de um compilador. Desenhada com objetivos de adicionar suporte para otimizações em tempo de execução não custosas, otimizações interprocedurais, análise completa do programa, transformações abrangendo nível de reestruturação, dentre outros, tem como aspecto mais importante o fato de ser definida como uma linguagem de primeira classe com semântica bem definida, tendo seu conjunto de instruções próximo do padrão RISC e possuindo como um de seus pilares a forma SSA ([LATTNER, 2011](#)).

Sendo a única interface para o otimizador do LLVM, se torna o único requisito para escrever um *front end* para a infraestrutura. Por possuir uma forma textual legível, desenvolver um front end que tem como saída a representação intermediária do LLVM se torna algo possível e viável. Tal característica é um dos principais fatores para a disseminação da infraestrutura do LLVM em diferentes aplicações, já que a completude presente na representação permite que o suporte de uma nova linguagem seja simplificado ([LATTNER, 2011](#)).

2.2.4 Vulnerabilidades de memória

Uma vulnerabilidade, segundo a CVE, é uma ou mais instâncias de fraquezas em um produto que podem ser exploradas, causando impactos negativos na confidencialidade, integridade e disponibilidade do produto, um conjunto de condições ou comportamentos que permitem a violação de políticas de segurança implícitas ou explícitas.

No contexto do desenvolvimento de software e análise de código, as vulnerabilidades de memória consistem em falhas no gerenciamento de espaço de endereçamento de um programa. Para o escopo deste trabalho, a análise concentra-se especificamente nas instâncias de fraquezas que afetam os dados alocados dinamicamente na memória *Heap*. Na literatura, essas anomalias - que frequentemente envolvem o controle inadequado de ponteiros - são comumente referidas como “corrupção de memória” ou “vazamentos de memória”. No entanto, o termo mais abrangente “vulnerabilidades de memória” foi escolhido para utilização para evitar ambiguidades com classificações específicas, como a CWE-401 (*Memory Leak*), uma vez que o analisador proposto visa englobar anomalias que afetam a memória dinâmica.

Segundo o *Microsoft Security Response Center* (MSRC) ([THOMAS, 2019](#)), entre o período de 2004 a 2018 aproximadamente 70% das vulnerabilidades corrigidas mapeadas a um CVE foram causadas por desenvolvedores que de forma desavisada adicionaram problemas relacionados a vulnerabilidades de memória em seus códigos escritos nas linguagens C e C++. Além disso, a medida que a base de código da Microsoft era

incrementada e mais código aberto era utilizado, tal problema continuava a aumentar.

2.2.4.1 *Common Weakness Enumeration* (CWE)

A *Common Weakness Enumeration* (CWE) consiste em uma lista desenvolvida de forma colaborativa, que relaciona fraquezas recorrentes em software e hardware. No contexto de segurança, uma fraqueza (*weakness*) é uma condição num software, firmware, hardware, ou serviço que, a partir de certas circunstâncias, pode contribuir para a introdução de vulnerabilidades. Fraquezas são identificadas, classificadas, descritas e integradas à lista oficial da CWE (*CWE List*). A compreensão dessas fraquezas que resultam em vulnerabilidades permite que desenvolvedores de software, designers de hardware, e arquitetos de segurança atuem na mitigação e eliminação de tais fraquezas ainda nas fases iniciais do ciclo de desenvolvimento ([The MITRE Corporation, 2026a](#)).

A lista CWE é atualizada de três a quatro vezes por ano, incluindo novas descobertas e atualizando itens registrados anteriormente. Antes da publicação oficial, o conteúdo em desenvolvimento é disponibilizado e pode ser acompanhado através do *CWE Content Development Repository* (CDR), sendo um repositório público com objetivo de garantir transparência e colaboração da comunidade, viabilizando a submissão de novas fraquezas, contribuições para registros existentes e acompanhamento das operações internas da CWE ([The MITRE Corporation, 2026a](#)).

Para o escopo deste trabalho, serão consideradas primariamente três vulnerabilidades presentes na lista oficial da CWE, diretamente relacionadas a falhas de memória. São elas:

- **CWE-401:** *Missing Release of Memory after Effective Lifetime*
- **CWE-415:** *Double Free*
- **CWE-416:** *Use After Free*

2.2.4.2 CWE-401

Conforme a [OWASP Foundation \(2026b\)](#), um vazamento de memória é uma forma não intencionada de consumo de memória, ocorrendo quando o desenvolvedor falha em liberar um bloco de memória alocada quando a mesma não é mais necessária. Sendo dividido, de forma geral, em três cenários:

- Aplicações de curta duração (*Short Lived User-Land Application*), tendo pouco ou nenhum impacto notável, levando em consideração que sistemas operacionais modernos obtêm a memória perdida após o programa ser encerrado.
- Aplicações de longa duração (*Long Lived User-Land Application*), tendo riscos potenciais já que tais programas continuam perdendo memória ao longo do tempo, causando, eventualmente, o consumo integral dos recursos da memória RAM.

- Processos em nível de núcleo (*Kernel-land Process*), sendo o caso com nível mais alto de consequências, trazendo vazamentos de memória a nível de *Kernel*, gerando problemas de estabilidade voltados ao sistema.

2.2.4.3 CWE-415

Com o título de liberação dupla (*double free*), ocorre quando o mesmo endereço de memória é liberado mais de uma vez. Isso acontece pois, quando o programa chama a função de liberação (como a função *free()* da biblioteca *stdlib*, na linguagem C) utilizando o mesmo endereço de memória como argumento, a estrutura de dados responsável por gerenciar a heap pode ser corrompida, permitindo assim que um usuário malicioso escreva em posições arbitrárias de memória. O impacto de tal corrupção pode causar desde a falha abrupta do programa até a alteração do fluxo de execução. Ao sobrescrever registradores ou endereços específicos de memória, um atacante pode alterar o programa, sendo capaz de injetar e executar códigos arbitrários, resultando, por exemplo, na escalada de privilégios sobre o sistema em um emulador de terminal ([OWASP Foundation, 2026a](#)).

2.2.4.4 CWE-416

O *Use After Free* é a referenciação de um endereço de memória que foi desalocado, tal ato gera consequências imprevisíveis no sistema, com resultados que variam desde uma falha abrupta do programa até a execução de códigos e comandos arbitrários, dependendo do contexto e do momento que a vulnerabilidade ocorre. A reutilização de um endereço desalocado, segundo a [OWASP Foundation \(2026c\)](#), é a forma mais simples de corrupção de dados, visto que, neste cenário, o bloco de memória anteriormente liberado pode ser realocado para um novo objeto válido ao longo da execução do programa. Com isso o ponteiro original ainda aponta para esse endereço (se tornando um ponteiro pendente, ou *dangling pointer*), qualquer alteração feita através dele corromperá os dados da nova alocação legítima, gerando a falha imprevisível.

2.2.4.5 Common Vulnerabilities and Exposures (CVE)

Criado em 1999 pela corporação MITRE, o programa CVE (*Common Vulnerabilities and Exposures*) visa padronizar a identificação e catalogação de vulnerabilidades de segurança cibernética na indústria de tecnologia ([The MITRE Corporation, 2026b](#)).

A Lista CVE (*CVE List*) atua como um dicionário onde cada entrada documenta uma falha real detectada em uma versão específica de um software. Após a confirmação, a vulnerabilidade recebe um identificador único composto pelo ano de relato ou atribuição, seguido por um sequencial numérico. Após o processo de adição de uma entrada ao dicionário, plataformas como o *National Vulnerability Database* (NVD) incrementam o registro com dados críticos, como descrição técnica, índice de severidade metrificado pela

CVSS (*Common Vulnerability Scoring System*) e causa raiz da falha proveniente da Lista CWE ([The MITRE Corporation, 2026b](#)).

2.2.5 *Heap Object Flow Graph* (HOFG)

O *Heap Object Flow Graph* é uma representação de programa baseada nos blocos de memória alocados na *Heap*. Os vértices de tal grafo são constituídos pelas variáveis do programa que atuam como ponteiro para esses blocos de memória. Para converter um programa em sua representação HOFG, é necessário que seja primeiramente convertido para a forma SSA. Tal feito é necessário pois a forma SSA permite a visualização de forma explícita da definição e usos de cada variável, auxiliando assim, na distinção entre as suas atribuições e seus usos ([C; CHERAMANGALATH, 2023](#)).

Além disso, as definições e usos indiretos dos objetos também precisam ser levados em consideração para variáveis cujos endereços são referenciados ou para ponteiros de níveis superiores. Tais dados são capturados por meio das informações de ponteiro embutidas no HOFG. A incorporação de informações de ponteiros sem um módulo de análise de ponteiros separado é uma das peculiaridades do HOFG. A análise estática presente no *Heap Object Flow Graph* rastreia o fluxo de objetos alocados na *Heap* para verificar se tais itens alcançam, ou não, um nó de liberação de memória ([C; CHERAMANGALATH, 2023](#)).

Além das informações de definições e usos, o HOFG também incorpora o fluxo de controle, o que adiciona sensibilidade de fluxo à análise. A geração do HOFG e sua análise seguem os seguintes passos ([C; CHERAMANGALATH, 2023](#)):

- Geração do HOFG para o programa inteiro.
- Poda de caminhos sem vazamentos.
- Detecção de vazamentos a partir do HOFG podado.

2.2.5.1 Geração do HOFG para o programa inteiro

A implementação do HOFG tem como base a infraestrutura do *framework* LLVM. Inicialmente o código-fonte é compilado, arquivo por arquivo, para a obtenção de sua versão *bytecode* (.bc). Em seguida, tais arquivos são vinculados em tempo de ligação (*link time*) com o uso do *LLVM Gold Plugin*, fornecendo, desta maneira, um arquivo *bitcode* unificado representando o programa completo. Dessa forma, o LLVM auxilia na garantia de um dos requisitos da análise de códigos-fonte, sendo a necessidade de lidar com dependências entre múltiplos módulos de código-fonte ([C; CHERAMANGALATH, 2023](#)).

Este *bitcode* unificado é então convertido para a forma SSA a partir da chamada do passe *mem2reg pass*, nativo do LLVM. Por fim, o arquivo binário de todo o programa,

Algoritmo 1 Geração do Grafo de Fluxo de Objetos na *Heap* (HOFG)**Entrada:** Função F na forma de Representação Intermediária (IR)**Saída:** Grafo $HOFG(V, E)$ atualizado com os vértices e arestas da função

```

1: Função CONSTRUIRHOFG( $F$ )
2:   for cada bloco básico  $B$  na Função  $F$  do
3:     for cada instrução  $I$  no bloco básico  $B$  do
4:       if  $I$  é uma instrução de alocação de memória da forma:  $p = \text{malloc}(o)$  then
5:         Adicionar os vértices  $o_i$  e  $p$  ao conjunto  $V$  e a aresta  $o_i \rightarrow p$  a  $F$ 
6:       end if
7:       if  $I$  é uma instrução de liberação de memória:  $\text{free}(p)$  then
8:         if  $p \in V$  then
9:           Adicionar aresta de  $p$  para um novo nó free
10:        end if
11:      end if
12:      if  $I$  é uma instrução de cópia da forma:  $q = p$  then
13:        if  $p \in V$  then
14:          if  $q \notin V$  then
15:            Adicionar vértice  $q$  a  $V$ 
16:          end if
17:          Adicionar aresta de fluxo  $p \rightarrow q$  a  $F$ 
18:        end if
19:      end if
20:      if  $I$  é uma instrução de desreferenciamento de ponteiro (ex:  $*p$ ) then
21:        if  $p \in V$  then
22:          if  $*p \notin V$  then
23:            Adicionar  $*p$  a  $V$ 
24:          end if
25:          Adicionar aresta de desreferenciamento  $p \rightarrow *p$  a  $R$ 
26:        end if
27:      end if
28:      if  $I$  é uma instrução de carregamento (load):  $q = *p$  then
29:        if  $*p \in V$  then
30:          if  $q \notin V$  then
31:            Adicionar  $q$  a  $V$ 
32:          end if
33:          Adicionar aresta de fluxo  $*p \rightarrow q$  a  $F$ 
34:        end if
35:      end if
36:      if  $I$  é uma instrução de armazenamento (store):  $*p = q$  then
37:        if  $q \in V$  then
38:          if  $*p \notin V$  then
39:            Adicionar  $*p$  a  $V$ 
40:          end if
41:          Adicionar aresta de fluxo  $q \rightarrow *p$  a  $F$ 
42:        end if
43:        if  $p \rightarrow q \in F$  e as arestas  $p \rightarrow *p, q \rightarrow *q \in R$  then
44:          Adicionar aresta de fluxo derivado  $*p \rightarrow *q$  em  $D$  com as mesmas restrições
            de caminho que  $p \rightarrow q$ 
45:        end if
46:      end if
47:    end for
48:  end for
49: end Função

```

agora no formato SSA, se torna entrada para o programa responsável por analisar o HOFG e verificar os vazamentos de memória (C; CHERAMANGALATH, 2023).

O HOFG captura o fluxo de cada bloco de memória alocado na *Heap* através das variáveis (ponteiros) presentes no programa. Trata-se de uma representação seletiva, que captura apenas as partes do código que possuem envolvimento com a memória alocada na *Heap* e nos caminhos que essa memória percorre até alcançar diferentes pontos de execução. Cada atribuição de uma variável de ponteiro é registrada na representação, desde que tenha como origem um bloco alocado na *Heap*. A representação de programa foi projetada de tal sorte que toda e qualquer informação de ponteiros necessária para a detecção de erros esta armazenada na sua própria estrutura (C; CHERAMANGALATH, 2023).

A geração do HOFG é iniciada pela geração de sumários de funções. Tais sumários registram as propriedades da função que afetam os componentes do HOFG, sendo uma etapa fundamental para a análise interprocedural (C; CHERAMANGALATH, 2023).

O processo da geração de sumários realiza as seguintes etapas para cada função analisada (C; CHERAMANGALATH, 2023):

- Geração do HOFG local da função.
- Ao encontrar uma instrução de chamada de função, é gerado o sumário da função chamada (*callee*), se o mesmo não estiver disponível.
- Aplicação do sumário da função chamada, se estiver disponível. Esta etapa envolve a adição de arestas direcionadas para (ou a partir de) argumentos reais e formais.
- Atualização do sumário da função atual.

O *Heap Object Flow Graph* é definido como um grafo orientado $HOFG(V, E)$, onde (C; CHERAMANGALATH, 2023):

$$E = \{\text{arestas de fluxo } F, \text{arestas de desreferenciamento } R, \\ \text{e arestas de fluxo derivado } D\} \quad (2.1)$$

$$V = \{\text{objetos alocados na memória } Heap \ o_i, \text{variáveis de programa } p, p^*, \dots, \\ \text{nós de liberação } free_i\} \quad (2.2)$$

O grafo do HOFG é construído de acordo com as regras descritas no 1. As condições que anotam as arestas do HOFG são derivadas das transições entre os blocos básicos e dos identificadores de blocos básicos que possuem associação com as instruções do programa (C; CHERAMANGALATH, 2023).

O número de vértices presente no HOFG depende da quantidade real de instruções que possuem ponteiros para a memória *Heap* como operandos. Considerando N como o total de linhas de código (LoC) do programa, o pior caso ocorre quando cada instrução

possui um objeto alocado na memória *Heap* como operando, o que limita a complexidade de espaço a $O(N)$ (C; CHERAMANGALATH, 2023).

Enquanto isso, o número de arestas no grafo depende do caminho de fluxo do objeto, isto é, do número de vezes que o seu valor é utilizado ou copiado após a alocação. Dessa forma, esse número varia para cada objeto alocado no programa. E, assim como ocorre com o número de vértices, a complexidade espacial referente ao número máximo de arestas também pode ser delimitado superiormente por $O(N)$, pois, num pior caso, é considerado como o número total de linhas de código (LoC) no programa (C; CHERAMANGALATH, 2023).

2.2.6 Value-Set Analysis

O *Value-Set Analysis* (VSA) é uma técnica de interpretação abstrata de código executável, que tem como objetivo encontrar uma aproximação segura para o conjunto de valores que cada objeto de dados pode armazenar em cada ponto de um programa (BALAKRISHNAN, 2007). A interpretação abstrata atua, neste caso, como uma base matemática sólida que relaciona a semântica formal do programa com o modelo de análise, garantindo matematicamente a correção (*soundness*) e a precisão dessas aproximações (MÖLLER; SCHWARTZBACH, 2018).

O VSA possui similaridades com o problema de análise de ponteiros (*pointer-analysis*), frequentemente estudado em análises de programas escritos em linguagens de alto nível. Enquanto a análise de ponteiros tradicional determina uma sobreaproximação (*over-approximation*) de conjunto de variáveis cujos endereços uma determinada variável pode conter, o VSA atua determinando uma sobreaproximação do conjunto de endereços que cada objeto de dados pode conter em cada ponto do programa (BALAKRISHNAN, 2007).

Como consequência, os resultados do VSA podem ser utilizados para identificar quais *a-locs* (*abstract locations*) estão contidos nos endereços de um determinado *a-loc*. Por outro lado, o VSA também possui características de análises estáticas numéricas. Além de rastrear endereços, o algoritmo determina uma sobreaproximação do conjunto de valores inteiros que cada objeto de dados pode assumir ao longo da execução (BALAKRISHNAN, 2007).

2.2.6.1 Regiões de memória (*Memory-Regions*)

Em programas compilados, modelar a memória como um vetor plano de bytes apresenta limitações severas para a análise (BALAKRISHNAN, 2007):

- Pode se tornar impossível determinar endereços de memória específicos para certos blocos de memória, como endereços alocados a memória *Heap* via `malloc`.
- Endereços da pilha de execução são reutilizados ao longo da execução do programa, significando que, uma determinada área da pilha será utilizada por diferentes proce-

dimentos (tais como funções) em diferentes momentos da execução. Por isso, a cada instrução um específico endereço de memória pode ser ambíguo.

Para que tais problemas sejam contornados, o espaço de endereçamento do programa é dividido em áreas independentes e não sobrepostas, referenciadas como regiões de memória (*memory-regions*) (BALAKRISHNAN, 2007).

Cada região de memória representa um grupo de localizações que possui propriedades similares em tempo de execução. Cada byte (abstrato) em uma região de memória representa um conjunto de endereços de memória concretos. Para um programa, existem três tipos de regiões: A (1) região global (*global-region*), para endereços de memória que armazenam dados globais inicializados e não inicializados. (2) *AR-Regions*, cada um contendo a localização dos ARs (*Activation Records*) de um procedimento em particular. E, por fim, (3) *malloc-regions*, cada um dos quais contém os endereços alocados em um local de `malloc` em específico (BALAKRISHNAN, 2007).

2.2.6.2 Abstract Locations (A-Locs)

Regiões de memória provém uma forma de resumir as informações sobre o conjunto de endereços concretos, porém por si só não disponibilizam uma representação para variáveis presentes no código-fonte do programa. Isso ocorre pois, em executáveis, tais variáveis provenientes do código-fonte não existem, sendo necessária a construção de entidades semelhantes a tais variáveis a partir do executável. A essas entidades com semelhança a variáveis é atribuída a nomenclatura *a-loc* (para "*abstract location*", ou localização abstrata) (BALAKRISHNAN, 2007).

Cada *a-loc* identificado é mapeado a uma tripla (`rgn`, `off`, `size`), na qual o *rgn* representa a região de memória pertencente àquele *a-loc*, o `off` é a posição inicial do deslocamento do *a-loc* dentro do *rgn*, bem como o `size` é o tamanho de um *a-loc*. O começo do deslocamento de um *a-loc* a em uma região *rgn* é denotada por `offset(rgn, a)` (BALAKRISHNAN, 2007).

Além disso, o tamanho (`size`) pode não ser conhecido estaticamente, como os blocos alocados dinamicamente na memória *Heap*, caso em que o tamanho assume o valor infinito (∞). Cabe ressaltar que nem todos os *a-locs* surgem com declarações explícitas, alguns são gerados sinteticamente pela análise, como os *a-locs* estendidos, que representam parâmetros e dados empurrados implicitamente para a pilha de execução via instruções de `push` (BALAKRISHNAN, 2007).

2.2.6.3 Value-Set

Para representar a junção de endereços de memória e valores numéricos, o VSA utiliza uma estrutura matemática chamada *Value-Set* (conjunto de valores). Um *Value-Set* é representado com uma tupla de intervalos com passo (*strided intervals*, ou SI) de *k*-bits, sim-

bolizando o conjunto de deslocamentos (*offsets*) em cada região de memória. Um intervalo com passo de k -bit $s[l, u]$ representa o conjunto de números inteiros (BALAKRISHNAN, 2007):

$$\{i \in [-2^{k-1}, 2^{k-1}] \mid l \leq i \leq u, i \equiv l \pmod{s}\} \quad (2.3)$$

A partir disso:

- s é chamado de passo (*stride*).
- $[l, u]$ é chamado de intervalo.
- $0[l, l]$ representa um conjunto unitário.
- $\perp$ também sendo considerado um intervalo com passo, denota um conjunto vazio de deslocamentos.

Considere o conjunto de endereços:

$$S = (Global \rightarrow \{1, 3, 5, 9\}), (AR_{Main} \rightarrow \{-48, -40\}) \quad (2.4)$$

O *Value-Set* de S é o conjunto:

$$(Global \rightarrow 2[1, 9]), (AR_{Main} \rightarrow 8[-48, -40]) \quad (2.5)$$

Em tal cenário, o *Value-Set* de S é uma *over-approximation*, pois o *Value-Set* contempla o endereço global 7, que não é um elemento de S . Além disso, um *Value-Set* é capaz de representar tanto um conjunto de endereços de memória, quanto um conjunto de valores numéricos. Dessa forma, a 2-tupla $(2[1, 9], \perp)$ indica o conjunto de valores numéricos $\{1, 3, 5, 7, 9\}$, assim como indica o conjunto de endereços $(Global, 1), (Global, 3), \dots, (Global, 9)$ (BALAKRISHNAN, 2007).

2.3 Métricas de Avaliação

Esta seção detalha a metodologia de avaliação do analisador estático proposto. Divide-se em duas frentes: a verificação de precisão, realizada por meio do Juliet Test Suite (Subseção 2.3.1), e a mensuração de desempenho em cenários reais de software, através de casos aplicados (Subseção 2.3.2).

2.3.1 Juliet Test Suite

O Juliet Test Suite é uma coleção de programas escritos em C/C++ e Java, sendo casos de teste sintéticos, isto é, foram desenvolvidas como exemplos de vulnerabilidades caracterizadas (BOLAND; BLACK, 2012).

A coleção foi desenvolvida pela National Security Agency's Center for Assured Software, estando em domínio público. Segue uma estrutura focada em funções disponíveis na plataforma subjacente e não em bibliotecas de terceiros. Fora desenvolvida no Microsoft Windows, porém boa parte dos programas teste foram desenvolvidos sem a utilização de funções provenientes de uma plataforma ou sistema operacional específica, e, além disso, todos os casos de teste foram compilados (BOLAND; BLACK, 2012).

O Juliet Test Suite será utilizado para avaliar a precisão do analisador implementado sob a representação de programa, quantificando a taxa de falsos positivos, falsos negativos, verdadeiros positivos e verdadeiros negativos, bem como o *f1 score*, através da análise de seus casos de teste. Para a avaliação, serão considerados os casos de teste que compõem CWEs com tema principal corrupção de memória, pela natureza do HOFG, bem como CWEs com base em acessar endereços de memória que ultrapassam os limites armazenados de objetos.

Os CWEs considerados serão:

- CWE-401
- CWE-415
- CWE-416

2.3.2 Casos aplicados

Além dos casos pertencentes ao *Juliet Test Suite*, que têm como objetivo validar a precisão de detecção do analisador, a avaliação engloba ainda a análise do código-fonte de projetos de código aberto. Essa etapa visa mensurar o custo computacional da própria ferramenta, registrando o consumo máximo de memória RAM, a utilização da CPU e o tempo (em segundos) que o analisador levou para processar os arquivos de cada projeto.

A seleção dos projetos de código aberto teve como base os critérios de relevância industrial, diversidade de domínios tecnológicos e implementação nativa na linguagem C.

Os projetos escolhidos foram:

- gcc, compilador da linguagem C do projeto GNU.
- sqlite, motor de banco de dados relacional embutido e autônomo, utilizado em aplicações locais e móveis.

2.4 Trabalhos relacionados

Esta seção detalha três artigos fundamentais para o escopo desta pesquisa: o Trabalho 1 (2.4.1), artigo seminal que propõe a estrutura HOFG original, o Trabalho 2 (2.4.2), que apresenta o LeakGuard, ferramenta com arquitetura escalável e método automático

para detecção de funções de alocação e desalocação (MAD *functions*), e o Trabalho 3 (2.4.3), que apresenta o Infer, ferramenta que utiliza análise composicional para detecção de vulnerabilidades.

2.4.1 Trabalho 1: *Memory leak detection using Heap Object Flow Graph* (HOFG)

O artigo que apresenta a representação de programas HOFG, apresenta também o *HOFG-Analyser*, um analisador de código estático baseado nessa estrutura para a detecção de vazamentos de memória. A ferramenta foi implementado sobre o LLVM *framework* versão 12 e o compilador Clang 3.8. Conforme destacado pelos próprios autores, o analisador assume certas concessões em sua corretude (*unsound trade-offs*), de forma similar como ocorre em abordagens anteriores (C; CHERAMANGALATH, 2023).

O primeiro ponto ocorre em caminhos que são finalizados com outra chamada de função de biblioteca que não seja a função *free()*, em tais casos o rastreamento do objeto alocado na *Heap* é interrompido. Além disso, é pontuado que operações aritméticas complexas envolvendo ponteiros não são rastreadas com precisão. Isto é, dado um ponteiro p , as operações $q = p + 1$ e $q = p$ resultam na adição de uma mesma aresta do ponteiro p para o ponteiro q no HOFG. Consequentemente, as instruções *free(p)* e *free(q)* seriam interpretadas de forma simplificada como a liberação do mesmo objeto na memória *Heap* (C; CHERAMANGALATH, 2023).

O *HOFG-Analyser* foi comparado com a ferramenta de código aberto INFER, utilizando oito programas de referência do SPECINT2006 e três projetos de código aberto. A análise classifica as vulnerabilidades encontradas em duas categorias, possíveis vazamentos (*may-leak points*), sendo percursos no HOFG que tem seu destino um nó de liberação, mas que possuam arestas anotadas com condições que só podem ser resolvidas em tempo de execução. E vazamentos confirmados (*must-leak points*), sendo percursos presentes no HOFG que não terminam em um nó de liberação (C; CHERAMANGALATH, 2023).

Diante das limitações relacionadas ao tratamento de aritmética de ponteiros no *HOFG-Analyser* a integração com o *Value-Set Analysis* (VSA) é apresentada como uma abordagem viável. A fragilidade encontrada no HOFG pode ser superada ao se utilizar as aproximações de valores (presentes em intervalos válidos) que cada variável pode assumir em tempo de execução, sendo calculadas através do VSA. Logo, em uma operação como $q = p + 1$, o VSA tem a capacidade de verificar se o deslocamento calculado resulta em um endereço válido que a variável q possa assumir. Ao calcular a diferença de endereços abstratos (*a-locs*) entre p e q , torna-se viável validar ou impedir a criação de uma aresta interligando tais ponteiros no HOFG. Com isso, a integração de HOFG e VSA atuaria como um filtro, capaz de reduzir a imprecisão da análise realizada pelo *HOFG-Analyser*.

2.4.2 Trabalho 2: *LeakGuard: Detecting Memory Leaks Accurately and Scalably*

O *LeakGuard* tem como objetivo a detecção de vazamentos de memória de forma escalável e precisa, possui fluxo de análise dividido em quatro partes (LIANG et al., 2025):

- Fase 1: Pré-processamento do projeto sob teste. Realizado pois softwares reais possuem diversos arquivos de código fonte e configuração de compilação, contendo regras e comandos para a compilação do projeto completo. Enquanto o projeto é compilado, o *LeakGuard* armazena o processo num banco de dados de compilação, sendo utilizado posteriormente.
- Fase 2: Modelagem das funções de alocação e desalocação (*memory allocation/deallocation* - MAD). Detectadas por meio de um processo iterativo, inicializado pela consulta ao grafo de chamadas com objetivo de identificar todas as funções que invocam funções MAD padrão já conhecidas. Após isso, é empregada uma análise de fluxo de dados sensível ao caminho (*path-sensitive*) para mapear novas funções MAD dentro destas funções chamadoras, refinando os respectivos sumários. Esta etapa é realizada até que nenhum sumário adicional seja incorporado.
- Fase 3: Reconhecimento de funções chamadoras. As funções que realizam chamadas para as funções MAD identificadas na fase 2 são filtradas. Todas as funções que não lidam com operações de memória são ignoradas, partindo do pressuposto lógico de que não pode haver vazamentos em funções que não alocam ou liberam memória.
- Fase 4: Detecção de vazamentos. É aplicada a execução simbólica sub-restrita (*under-constrained symbolic execution*) e uma análise sensível ao caminho nas funções chamadoras filtradas na fase anterior. Permitindo que haja foco direto da execução simbólica sobre os pontos de interesse. A ferramenta rastreia o ciclo de vida da memória dinâmica e utiliza um *solver SMT* para verificar se o caminho que gera a falha é realmente viável. Além disso, um mecanismo de análise de escape de ponteiros foi desenvolvido, baseado no fluxo de dados, confirma se a memória foi de fato abandonada ou se seu controle foi transferido para uma variável global, estrutura de dados, parâmetros ou retornos de funções.

Possui como diferencial a modelagem de funções MAD personalizadas, sendo uma das principais motivações para o desenvolvimento da ferramenta. Visto que outras ferramentas apresentam dificuldades na modelagem de tais funções pelo frequente emprego de análises insensíveis ao caminho, que mesclam ramificações do código em uma tentativa de evitar a explosão de estados da função (*path explosion*). Com isso, o próprio rastreamento de ponteiros se torna impreciso, pois as condições reais de atribuições e operações são perdidas ou desconsideradas (LIANG et al., 2025).

Em contraste, o *LeakGuard* realiza uma análise de fluxo de dados de baixo para cima, sensível ao caminho e ao campo (*field-sensitive*), permitindo rastrear com precisão operações de memória aninhadas e identificar se as alocações dependem de parâmetros condicionais em tempo de execução (LIANG et al., 2025).

2.4.3 Trabalho 3: *Infer - An Automatic Program Verifier for Memory Safety of C Programs*

Infer é uma ferramenta comercial avançada voltada para verificação de segurança de memória de programas escritos em C. Realiza uma análise profunda de memória (*deep-heap analysis*) sem exigir anotações prévias ou modificações por parte do programador, permitindo a realização de análises de forma automatizada. Possui como base primária dois conceitos centrais, a bi-abdução (*bi-abduction*), e a análise composicional (CALCAGNO; DISTEFANO, 2011).

A bi-abdução, sendo um processo matemático de inferência, é utilizado pelo *Infer* com o objetivo de deduzir como uma determinada função opera sobre a memória dinâmica. O feito é realizado por meio da resolução lógica de duas partes do estado da memória, o *anti-frame*, representando a porção de memória que um procedimento precisa para ser executado com segurança, mas que não está presente no estado atual da análise, e o *frame*, representando porções de memória que existem no contexto atual, mas que não serão tocadas ou alteradas pela operação da função (CALCAGNO et al., 2011).

Graças a capacidade de sintetizar as especificações utilizando a bi-abdução, o *Infer* realiza uma análise composicional, em que cada procedimento é analisado de forma independente de seus chamadores, numa abordagem de baixo para cima (*bottom-up*). O objetivo principal de tal análise é descobrir automaticamente invariantes que descrevem o uso das estruturas de dados do programa, a fim de provar a segurança de ponteiros, sem exigir que o programador escreva especificações manuais (CALCAGNO; DISTEFANO, 2011).

Com tal análise, benefícios são alcançados para a verificação de software (CALCAGNO; DISTEFANO, 2011):

- Capacidade de analisar códigos incompletos: Fragmentos isolados de código podem ser analisados sem a necessidade de criar um contexto específico ou uma função principal (*main*) simulada apenas para que a análise possa ser realizada.
- Potencial para escalabilidade: A partir da análise dos procedimentos de forma isolada, se torna mais fácil executar a análise de forma paralela (aproveitando múltiplos núcleos de processamento) e aplicá-la a bases de código de maiores tamanhos. Além disso, o algoritmo é naturalmente incremental, o que permite que alterações futuras no código exijam uma nova análise somente das funções afetadas, mantendo os resultados das demais.

- Imprecisão graciosa (*graceful imprecision*): Com a abordagem composicional, ao serem encontradas limitações e não ser possível obter um resultado preciso para uma função específica, tal falha é isolada. O que permite que o sistema continue a oferecer provas lógicas precisas para o restante dos procedimentos do programa.

O *Infer* processa um projeto através de três etapas principais ([CALCAGNO; DISTEFANO, 2011](#)):

- *InferCapture*, responsável por converter o código para uma representação interna lógica.
- *InferAnalyser*, responsável por conduzir a verificação matemática profunda utilizando a bi-abdução.
- *InferPrint*, que emite relatórios de erros extraídos de provas falhas e listas de bugs em formatos diversos.

3 Desenvolvimento

O desenvolvimento deste trabalho de conclusão de curso está dividido em duas seções, sendo a primeira, 3.1 a solução proposta, na qual é discorrido o que será realizado para que os objetivos sejam alcançados, e a seção 3.2 cronograma de trabalho, expandindo como será realizada cada etapa da solução, bem como serão apresentados prazos para cada fase.

3.1 Solução proposta

A solução proposta gira em torno de um método de análise estática derivado do HOFG, incrementado pelo VSA, tal método unifica o rastreamento direcional do Grafo de Fluxo de Objetos em *Heap*, com a abstração numérica do VSA. Com essa modelagem, cada nó de origem do HOFG é mapeado para um *a-loc* correspondente, cujo intervalo de memória é rastreado através de *value-sets*. Durante a análise, os sumários de função do HOFG são expandidos para contemplar as mutações matemáticas desses *value-sets* resultantes dos nós adjacentes.

Com a introdução dessa camada de análise abstrata, é adicionada a detecção de vulnerabilidades não cobertas pelo HOFG tradicional. Atribuições tais como $p = q$ são monitoradas para identificar a perda de referência da *a-loc* original de p , configurando vulnerabilidade de memória. De forma paralela, operações aritméticas envolvendo ponteiros (exemplo: $q = q + 1$) deixam de ser uma ponta solta, o VSA valida o passo (*stride*) e a congruência do intervalo matemático resultante. Se o novo *value-set* violar os limites estabelecidos para a *a-loc* de q , a análise aponta acesso a endereço de memória indevido e possível corrupção de memória.

Uma ferramenta de análise estática, cujo motor principal é baseado na construção do grafo HOFG integrado ao VSA será implementada, tal ferramenta terá como objetivo analisar o código-fonte de programas escritos na linguagem C, convertendo o código-fonte para a representação HOFG-VSA e realizando a busca por vazamentos a partir do grafo obtido. Ao contrário da abordagem monolítica adotada pelo *HOFG-Analyser* original, a nova ferramenta implementará um processamento modular de arquivos. Cada arquivo de código será convertido individualmente para o LLVM IR, do qual serão extraídos sumários de funções e objetos. Tal processamento individual permite economia de consumo de memória RAM, viabilizando a análise de projetos de larga escala, com centenas de milhares ou milhões de linhas de código (LoC).

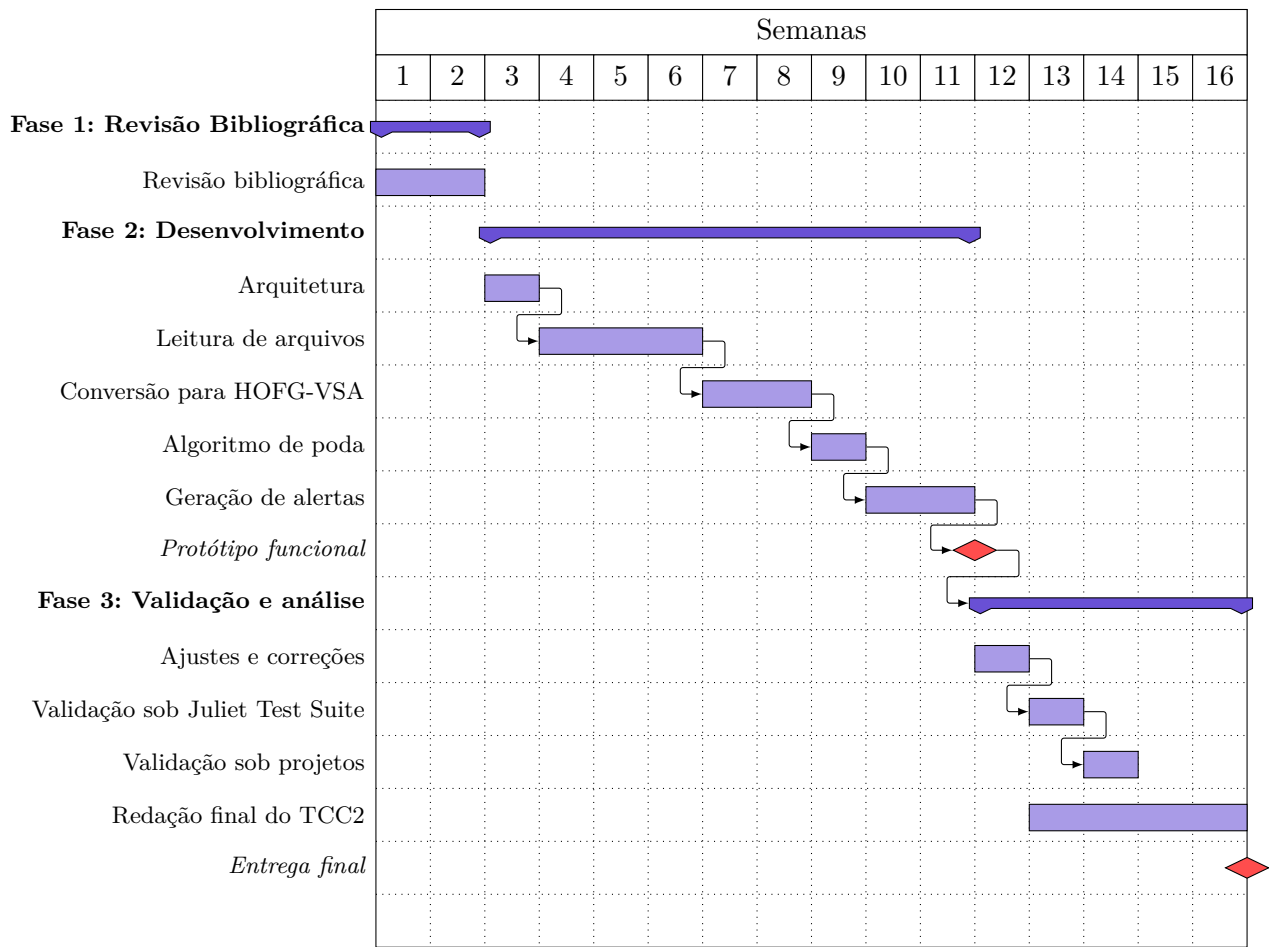
O desenvolvimento será realizado utilizando a linguagem Zig (versão 0.16). Embora o Zig ainda não tenha atingido sua versão estável, ele oferece recursos úteis para a arquitetura do analisador. Seu controle explícito e refinado no gerenciamento de memória otimiza o ciclo de vida dos nós que serão alocados e desalocados durante a montagem e análise do

grafo. Além disso, a interoperabilidade nativa com a linguagem C permite a integração direta com a API LLVM-C, o que possibilita a leitura de arquivos bitcode e extração das instruções responsáveis por operações na memória *Heap*.

3.2 Cronograma de trabalho

O cronograma a seguir apresenta, no formato de diagrama de Gantt, as atividades previstas para o desenvolvimento do TCC2, distribuídas ao longo das semanas do semestre.

Figura 5 – Cronograma de atividades – Diagrama de Gantt



Fonte: Elaborado pelo autor (2026)

Referências

- AHO, A. V. et al. *Compiladores: Princípios, Técnicas e Ferramentas*. 2. ed. [S.l.]: Pearson Addison-Wesley, 2009. Tradução de Daniel Vieira. 13
- BALAKRISHNAN, G. PhD thesis, *WYSINWYX: What You See Is Not What You Execute*. Madison, WI: [s.n.], 2007. Disponível em: <https://research.cs.wisc.edu/wpis/papers/balakrishnan_thesis.pdf>. 8, 9, 17, 18, 26, 27, 28
- BALAKRISHNAN, G.; REPS, T. Wysinwyx: What you see is not what you execute. *ACM Trans. Program. Lang. Syst.*, Association for Computing Machinery, New York, NY, USA, v. 32, n. 6, ago. 2010. ISSN 0164-0925. Disponível em: <<https://doi.org/10.1145/1749608.1749612>>. 7
- BOLAND, T.; BLACK, P. Juliet 1.1 c/c++ and java test suite. *Computer*, v. 45, p. 88–90, 10 2012. 28, 29
- BRYANT, R. E.; O'HALLARON, D. R. *Computer Systems: A Programmer's Perspective*. 2. ed. Upper Saddle River, NJ: Prentice Hall, 2010. 12
- C, H. M.; CHERAMANGALATH, U. Memory leak detection using heap object flow graph (hofg). Association for Computing Machinery, New York, NY, USA, 2023. Disponível em: <<https://doi.org/10.1145/3578527.3578528>>. 8, 9, 23, 25, 26, 30
- CALCAGNO, C.; DISTEFANO, D. Infer: an automatic program verifier for memory safety of c programs. In: *Proceedings of the Third International Conference on NASA Formal Methods*. Berlin, Heidelberg: Springer-Verlag, 2011. (NFM'11), p. 459–465. ISBN 9783642203978. 32, 33
- CALCAGNO, C. et al. Compositional shape analysis by means of bi-abduction. *J. ACM*, Association for Computing Machinery, New York, NY, USA, v. 58, n. 6, dez. 2011. ISSN 0004-5411. Disponível em: <<https://doi.org/10.1145/2049697.2049700>>. 32
- LATTNER, C. LLVM. In: BROWN, A.; WILSON, G. (Ed.). *The Architecture of Open Source Applications*. Lulu.com, 2011. v. 1, cap. 11. Acesso em: 13 abr. 2026. Disponível em: <<https://aosabook.org/en/v1/llvm.html>>. 19, 20
- LATTNER, C.; ADVE, V. Llm: A compilation framework for lifelong program analysis & transformation. In: *Proceedings of the International Symposium on Code Generation and Optimization: Feedback-Directed and Runtime Optimization*. USA: IEEE Computer Society, 2004. (CGO '04), p. 75. ISBN 0769521029. 19
- LIANG, H. et al. *LeakGuard: Detecting Memory Leaks Accurately and Scalably*. 2025. Disponível em: <<https://arxiv.org/abs/2504.04422>>. 31, 32
- MØLLER, A.; SCHWARTZBACH, M. I. *Static Program Analysis*. 2018. Department of Computer Science, Aarhus University, <http://cs.au.dk/~amoeller/spa/>. 8, 12, 14, 15, 16, 18, 26
- OWASP Foundation. *Doubly freeing memory*. 2026. Acesso em: 05 jun. 2026. Disponível em: <https://owasp.org/www-community/vulnerabilities/Doubly_freeing_memory>. 22

OWASP Foundation. *Memory leak*. 2026. Acesso em: 13 abr. 2026. Disponível em: <https://owasp.org/www-community/vulnerabilities/Memory_leak>. 21

OWASP Foundation. *Using freed memory*. 2026. Acesso em: 05 jun. 2026. Disponível em: <https://owasp.org/www-community/vulnerabilities/Using_freed_memory>. 22

SINGER, J. Introduction. In: RASTELLO, F.; Bouchez Tichadou, F. (Ed.). *SSA-based Compiler Design*. [S.l.]: Springer International Publishing, 2022. ISBN 978-3-030-80515-9. 16, 17

The MITRE Corporation. *About CWE*. 2026. Acesso em: 13 abr. 2026. Disponível em: <<https://cwe.mitre.org/about/index.html>>. 21

The MITRE Corporation. *About the CVE Program*. 2026. Acesso em: 03 mai. 2026. Disponível em: <<https://www.cve.org/About/Overview>>. 22, 23

THOMAS, G. *A proactive approach to more secure code*. 2019. Acesso em: 13 abr. 2026. Disponível em: <<https://www.microsoft.com/en-us/msrc/blog/2019/07/a-proactive-approach-to-more-secure-code>>. 7, 8, 18, 20